

Manual 34 — Implementación controlada de Gestión de Información de Privacidad ISO/IEC 27701:2025

****Idioma:**** Español de América Latina (es-419) — traducción no oficial del proyecto.

****Línea base:**** ISO/IEC 27701:2025, Edición 2. No se reproduce texto normativo protegido de ISO.

****Límite:**** esta guía de implementación no establece por sí sola certificación ni cumplimiento jurídico.

Chapter 01 — Propósito, alcance y jerarquía controlada de fuentes

Defina el objetivo del PIMS, sus límites organizacionales, clases de información, productos, servicios, entidades jurídicas, jurisdicciones e interfaces. Mantenga separadas las referencias a ISO/IEC 27701:2025, la integración con ISO/IEC 27001/27002, las leyes vinculantes, la guía regulatoria, los contratos y los procedimientos internos.

****Controles de implementación:**** aprobar alcance, exclusiones, interfaces y propietarios de fuentes; fechar cada reverificación.

****Evidencia:**** alcance aprobado, registro de fuentes, aplicabilidad y bitácora de verificación.

Chapter 02 — Contexto del PIMS y límites organizacionales

Documente condiciones internas y externas que afectan la gestión de privacidad, como modelo de negocio, escala de tratamiento, sensibilidad, tecnología, outsourcing, geografía y expectativas de stakeholders. Convierta el contexto en supuestos explícitos de diseño y disparadores de revisión.

****Controles:**** revisión al menos anual y tras cambios materiales; vincular cambios con riesgo y alcance.

****Evidencia:**** evaluación de contexto, diagrama de límites, registro de cambios y aprobación.

Chapter 03 — Partes interesadas e inventario de requisitos de privacidad

Identifique titulares de datos, clientes, reguladores, personal, proveedores, socios, auditores y otras partes relevantes. Traduzca requisitos aplicables a obligaciones controladas sin presentar toda expectativa como ley.

****Controles:**** mantener propietario, fuente, aplicabilidad, estado y evidencia.

****Evidencia:**** registro de interesados, inventario de requisitos y matriz de trazabilidad.

Chapter 04 — Determinación del alcance del PIMS y registro de aplicabilidad

Defina actividades de tratamiento, sistemas, ubicaciones, entidades, servicios y terceros dentro del PIMS. Registre justificación de exclusiones y dependencias para que cualquier afirmación de readiness no exceda el alcance gestionado.

****Controles:**** aprobación de management, mapeo de dependencias y reconciliación con inventarios.

****Evidencia:**** alcance PIMS, aplicabilidad y referencias a inventarios.

Chapter 05 — Liderazgo, política y accountability

Senior management debe establecer dirección, aprobar la política, asignar accountability, proveer recursos y revisar desempeño. Integre privacidad con enterprise risk e information security governance.

****Controles:**** política aprobada, ejecutivo accountable, cadencia de gobierno y ruta de escalamiento.

****Evidencia:**** política, charter, actas, decisiones y aprobaciones de recursos.

Chapter 06 — Roles de gobierno de privacidad y segregación de funciones

Defina responsabilidades para riesgo, ownership del tratamiento, sistemas, interpretación legal, security, procurement, incident response, internal audit y management review. Separe operación y revisión independiente cuando sea práctico.

****Controles:**** RACI, autoridades delegadas, revisión de conflictos y respaldo de funciones.

****Evidencia:**** matriz de roles, descripciones y delegaciones.

Chapter 07 — Gestión de riesgos y oportunidades de privacidad

Use un método repetible para identificar riesgos derivados de tratamiento, tecnología, personas, proveedores, jurisdicciones y cambios de ciclo de vida. Evalúe probabilidad e impacto con criterios definidos y documente decisiones de tratamiento.

****Controles:**** metodología aprobada, ownership, autoridad de aceptación y reevaluación periódica.

****Evidencia:**** registro de riesgos, planes, aceptaciones e historial de revisión.

Chapter 08 — Objetivos, métricas y planificación de privacidad

Defina objetivos medibles ligados a riesgo, prioridades de negocio, obligaciones y mejora continua. Especifique indicador, meta, propietario, frecuencia y umbral de remediación.

****Controles:**** objetivos aprobados y reglas de calidad de datos.

****Evidencia:**** registro de objetivos, KPI/KRI, dashboards y acciones.

Chapter 09 — Recursos, competencia, awareness y comunicaciones

Identifique competencias requeridas para governance, engineering, operations, procurement, incident response, audit y liderazgo. Proporcione capacitación por rol y defina comunicaciones internas y externas.

****Controles:**** criterios de competencia, planes de capacitación, seguimiento y rutas aprobadas.

****Evidencia:**** matriz de competencia, capacitación y plan de comunicaciones.

Chapter 10 — Gobierno de información documentada

Controle políticas, procedimientos, registros, workpapers, plantillas y evidencia del PIMS para asegurar versión, aprobación, protección, retención, recuperación y cambio autorizado.

****Controles:**** ownership, versionado, aprobación, retención, acceso y disposición.

****Evidencia:**** registro documental, historial, calendario de retención y accesos.

Chapter 11 — Planificación y control operacional

Convierta requisitos y tratamientos de riesgo en procedimientos repetibles para intake, uso, sharing, storage, change, retention, deletion, interacción con proveedores y excepciones.

****Controles:**** procedimientos, propietarios, aprobación de excepciones e impacto de cambios.

****Evidencia:**** procedimientos, logs, registro de excepciones y revisiones.

Chapter 12 — Responsabilidades del PII controller

Cuando la organización actúe como controller, gobierne propósitos, instrucciones de tratamiento, transparencia, soporte de derechos, sharing, retention, risk decisions y oversight de processors. Mantenga las obligaciones legales por jurisdicción como capa separada.

****Controles:**** determinación de rol, registros de propósito, oversight y escalamiento legal.

****Evidencia:**** evaluación de controller, processing records, notices y registros de oversight.

Chapter 13 — Responsabilidades del PII processor

Cuando la organización actúe como processor, controle recepción, validación, implementación y cambio de instrucciones del controller. Gestione subprocessors, confidencialidad, seguridad, retorno/eliminación, incident support y obligaciones contractuales.

****Controles:**** registro de instrucciones, contratos, subprocessor governance y terminación.

****Evidencia:**** evaluación de processor, logs, contratos y prueba de retorno/eliminación.

Chapter 14 — Procesos de soporte a derechos de titulares

Establezca intake, verificación de identidad, routing, fulfillment, excepciones, aprobación y evidencia para derechos aplicables. No presuma un conjunto universal de derechos o plazos.

****Controles:**** workflow por jurisdicción, protección de identidad, tracking y revisión legal.

****Evidencia:**** registro de solicitudes, verificación, respuesta y decisiones de excepción.

Chapter 15 — Soporte a propósito lícito y registros de tratamiento

Mantenga registros que identifiquen propósito, owner, categorías de datos, titulares, sistemas, destinatarios, jurisdicciones, retención y base legal/contractual cuando aplique. La determinación de base legal corresponde a funciones autorizadas.

****Controles:**** inventario de tratamiento, revisión de cambio de propósito y owner certification.

****Evidencia:**** processing records, aprobaciones, mapeos legales e historial.

Chapter 16 — Privacy by design y privacy by default

Integre privacidad en producto, servicio, arquitectura, procurement, analytics y change management antes de deployment. Las configuraciones por defecto deben reflejar objetivos y decisiones de riesgo aprobadas.

****Controles:**** design gates, requisitos, architecture review y aprobación de desviaciones.

****Evidencia:**** assessments, requisitos, decisiones y excepciones.

Chapter 17 — Minimización, exactitud, retención y disposición

Limite recolección y uso a propósito aprobado y necesidad operacional, mantenga exactitud apropiada, reglas de retención y eliminación, anonimización, retorno o archivo verificables.

****Controles:**** justificación de datos, retention schedule, deletion workflow y legal hold.

****Evidencia:**** revisiones de minimización, quality checks, reglas y disposal logs.

Chapter 18 — Transparencia y soporte de notices

Mantenga descripciones claras y controladas del tratamiento y revise notices cuando cambien de forma material el procesamiento, destinatarios, tecnología, geografía o requisitos.

****Controles:**** ownership, triggers, versionado y revisión de accesibilidad.

****Evidencia:**** inventario de notices, aprobaciones, historial y assessments.

Chapter 19 — Consentimiento y gestión de preferencias

Cuando consentimiento o preferencias formen parte del modelo aplicable, capture decisión, contexto, versión, fecha/hora, alcance y retiro/cambio de forma auditable. No use consentimiento como sustituto automático de análisis jurídico.

****Controles:**** criterios, preference store, retiro y propagación downstream.

****Evidencia:**** registros de consentimiento, preferencias, retiros y pruebas de sincronización.

Chapter 20 — Gobierno de proveedores, subprocessors y terceros

Aplique due diligence de privacidad basado en riesgo antes del onboarding y durante el ciclo de vida. Defina roles, flujos, jurisdicciones, contratos, expectativas, incident duties, audit rights, cambios y exit.

****Controles:**** tiering, due diligence, contract review, monitoring y exit controls.

****Evidencia:**** assessments, contratos, monitoring, remediation y terminación.

Chapter 21 — Transferencias transfronterizas y mapeo jurisdiccional

Mapee dónde se recopila, accede, almacena, soporta y transfiere PII. Enrute determinaciones sobre mecanismos y adecuación a funciones legales/privacy calificadas porque varían por jurisdicción.

****Controles:**** inventario de ubicación, transfer review, mecanismo aprobado y change control.

****Evidencia:**** transfer map, determinación legal, contratos y reevaluaciones.

Chapter 22 — Integración de controles de seguridad con ISO/IEC 27001 y 27002

Coordine controles de privacidad con el sistema de gestión de seguridad y safeguards técnicos. Riesgo de privacidad puede exigir controles adicionales y security controls por sí solos no demuestran privacy compliance.

****Controles:**** mapping privacy-security, ownership compartido, gaps y excepciones.

****Evidencia:**** crosswalk, vínculos risk/control, pruebas y remediation.

Chapter 23 — Soporte a incidentes de privacidad y breach response

Integre evaluación de privacidad en incident response para determinar datos, personas, jurisdicciones, obligaciones contractuales, posibles notificaciones, containment, remediation y preservación de evidencia. Las decisiones de notificación son jurisdiccionales.

****Controles:**** privacy triage, ruta legal/regulatoria, evidence preservation y lessons learned.

****Evidencia:**** incident record, impact assessment, notification decision y remediation.

Chapter 24 — Arquitectura de registros, evidencia y trazabilidad

Defina objetos de evidencia para demostrar decisiones, operación de controles, reviews, excepciones y corrective actions. Vincule evidencia con requisito, riesgo, control, owner, sistema/proceso, periodo y aprobación.

****Controles:**** taxonomía, naming/retention, acceso e integrity checks.

****Evidencia:**** evidence index, traceability matrix, retention e integrity metadata.

Chapter 25 — Monitoring, measurement, analysis y evaluation

Mida desempeño del PIMS y evalúe si los controles operan según lo previsto. Diferencie métricas operacionales de conclusiones de assurance.

****Controles:**** data owners, reglas de cálculo, thresholds, cadence y triggers de corrective action.

****Evidencia:**** dashboards, source records, trend analysis y acciones.

Chapter 26 — Internal audit del PIMS

Planifique auditorías basadas en riesgo con independencia suficiente. Defina alcance, criterios, evidencia, sampling, findings, reporting, remediation y follow-up.

****Controles:**** audit program, competencia/independencia, clasificación de findings y closure validation.

****Evidencia:**** plan, workpapers, findings, responses y cierre.

Chapter 27 — Management review

Management debe evaluar suitability, adequacy, effectiveness, riesgos significativos, auditorías, incidentes, objetivos, recursos, cambios de stakeholders y prioridades de mejora.

****Controles:**** agenda definida, inputs, tracking de decisiones y accountability.

****Evidencia:**** review pack, minutes, decisiones, acciones y cierre.

Chapter 28 — Nonconformity y corrective action

Ante falla de requisito o control, contenga, evalúe impacto, identifique causa, revise implicaciones sistémicas, corrija y verifique efectividad antes de cerrar.

****Controles:**** intake, root-cause method, ownership, fechas y effectiveness review.

****Evidencia:**** nonconformity record, root cause, remediation y validation result.

Chapter 29 — Mejora continua

Use tendencias de riesgo, auditorías, incidentes, métricas, feedback, cambios regulatorios/tecnológicos y lessons learned para priorizar mejoras.

****Controles:**** backlog, criterios de prioridad, benefit/risk assessment y governance review.

****Evidencia:**** backlog, roadmap, implementation records y outcome measures.

Chapter 30 — Límite de mapeo regulatorio y contractual

Mapee controles/evidencia del PIMS a leyes, regulaciones, guía, requisitos de clientes y contratos sin afirmar equivalencia. Un crosswalk es ayuda de trazabilidad, no prueba de cumplimiento automático.

****Controles:**** fuente/fecha/versión, rationale, legal review cuando aplique y non-equivalence statement.

****Evidencia:**** crosswalk register, rationale, approvals e historial.

Chapter 31 — Certification readiness, assurance y evidence package

Prepare evidencia controlada para readiness interno y assurance externo manteniendo el límite con certificación acreditada. Solo haga afirmaciones de certificación basadas en evidencia externa válida.

****Controles:**** evidence index, readiness review, gap closure y claim approval.

****Evidencia:**** readiness report, evidence pack, gap register y certificados válidos cuando existan.

Chapter 32 — Reverificación de fuentes y roadmap de implementación

Antes de cada release, confirme edición/estatus actual de ISO/IEC 27701, amendments/corrigenda relevantes, dependencias y overlays materiales. Congele identidades de fuente antes de generar candidatos y reinicie el ciclo ante cambios materiales.

****Controles:**** source verification, release checklist, source freeze, change triggers y predecessor check.

****Evidencia:**** source-state record, checklist, provenance manifest, QA results y publication approval.

Declaración controlada de release

Este manual es guía de implementación original. No es una publicación de ISO, no es una traducción autorizada por ISO y no confiere por sí solo certificación ni cumplimiento legal. Las conclusiones jurídicas deben ser realizadas por profesionales autorizados conforme a los hechos y la ley vigente.